# SyncPay — Project Summary

Oct 15, 2026 · @Ashish

## Overview

**SyncPay is a UPI-style wallet that lets people pay and get paid with no internet.** Payments are signed on the phone, exchanged as QR codes, and settle automatically once either phone gets a connection, over mobile data or plain SMS.

**Theme:** FinTech & Financial Inclusion, last-mile banking without internet.

### Problem

- Millions of people in rural and remote India have weak or no mobile internet, which shuts them out of digital payments.
- UPI and most wallets need both phones online at the moment of payment.
- Small merchants in low-connectivity areas fall back to cash, losing records, safety and access to digital credit.

### Solution

- **Online once:** sign up with a phone number and a WhatsApp OTP, set a PIN, and add money while connected.
- **Then pay offline:** the sender's phone signs the payment and shows it as a QR code. The receiver scans it and checks the signature on their own phone, with no internet on either side.
- **Settles later:** when either phone gets data, or just SMS signal, the signed payment reaches the server, which verifies it and moves the money.

## Features and how it works

All features below are built and working in the prototype.

| Feature | What it does |
| --- | --- |
| Offline QR payments | Person-to-person payments with no internet; QR valid for 60 seconds |
| Offline merchant payments | Shop shows a static QR; customer pays a payment addressed only to that shop |

| Feature | What it does |
|---|---|
| Automatic sync | Settles on reconnect, when the app opens, and every 20 s on the dashboard |
| SMS sync | With no data, signed payments go as an ordinary SMS through a gateway phone, which texts back a confirmation |
| WhatsApp OTP and alerts | Free login codes, plus money-received and payment-settled messages |
| Spending limits | Rs 500 per payment and Rs 2,000 per day offline, enforced on the phone and the server |
| Dashboard | Balance, locked and incoming funds, quick pay, recent activity, 7-day chart |
| History | Full history, including payments the other phone settled |
| Installable app (PWA) | Add to home screen; opens fully offline once installed |
| Modern UI | shadcn/ui, light and dark mode, phone and desktop |

## Step by step

1. **Sign up (online):** phone number, then WhatsApp OTP, then a 6-digit PIN. A signing key (Ed25519) is created on the phone, encrypted with the PIN (AES-256-GCM) and stored on the device. An encrypted backup on the server lets the wallet be restored on a new phone.
2. **Pay (offline):** the sender enters an amount and PIN. That amount is locked on the phone and a signed QR is shown.
3. **Receive (offline):** the receiver scans the QR, the signature is checked on their phone, and the payment shows as incoming and unconfirmed.
4. **Settle (whenever either phone has signal):** the server verifies the signature, rejects reused or duplicate payments, checks balance and limits, and moves the money in one step.
5. **Notify:** WhatsApp alerts to both people, plus an SMS reply when the payment was synced by SMS.

Paying a merchant follows the same steps. The customer first scans the shop's static QR, so the signed payment is addressed only to that shop.

# Architecture and security

The system has four parts: the phone app, the backend, a WhatsApp connection inside the backend, and an SMS gateway phone.

- **Phone app:** wallet, payment signing, QR codes, and the queue of payments waiting to settle.
- **Backend:** accounts, settlement, history and merchant totals.
- **WhatsApp connection:** runs inside the backend; sends OTP codes and payment alerts.
- **Gateway phone:** a spare Android phone that relays SMS sync messages to the backend and texts confirmations back.

## Technology stack

| Layer | Technology |
|---|---|
| Frontend | React 19 + Vite, installable web app (PWA) with service worker |
| UI | shadcn/ui (Radix + Tailwind CSS v4), lucide icons |
| Phone-side storage | IndexedDB for keys and transactions, Zustand for app state |
| Cryptography | Web Crypto API: Ed25519 signatures, PBKDF2 + AES-256-GCM key protection |
| QR | qrcode.react to generate; the browser's built-in QR detector, with jsQR as fallback, to scan |
| Backend | Node.js + Express 5, SQLite, JWT, Helmet, rate limiting |
| Messaging | WhatsApp via Baileys; SMS via SMS Gateway for Android (no Twilio) |

## Security model

| Threat | Protection |
|---|---|
| Forged or edited payment | Every payment is signed (Ed25519); amount and recipient are read only from the signed data |
| Replay or double settlement | Unique transaction IDs and per-sender sequence numbers; duplicate syncs are harmless |

| Threat | Protection |
|---|---|
| Someone else claiming money | A payment addressed to a person or shop can only be credited to them |
| Overspending offline | Funds locked on the phone; limits enforced on the phone and the server |
| Account takeover | OTP required for login; PIN unlock; 5 wrong PINs wipe the keys on that phone |
| Fake SMS webhook | Gateway messages signed with a shared key (HMAC-SHA256) and time-checked |
| Leaked secrets | Keys never leave the phone unencrypted; OTP codes are stored only as hashes |

# Testing, limitations and roadmap

## Testing and results

- **11 automated backend tests:** settlement attacks (inflated amounts, double claims, redirected payments, forged signatures, replays, limits) plus SMS parsing, signature and reply checks.
- **End-to-end tests:** QR and merchant payments; SMS sync through a signed webhook, including forged, unknown-number and duplicate messages; WhatsApp OTP and alerts on a real phone; the production build loading with the server switched off.
- **QR scanning fix:** the payment QR was too dense to scan reliably (436 characters, 77x77 grid). It was cut to 307 characters (61x61 grid), making each square about 45% larger, so phone-to-phone scanning now works.

## Current limitations

- **Prototype money:** top-ups and bank withdrawals are simulated; no real money moves.
- **Offline double-spending:** someone who wipes the app could try to spend the same balance twice. The second payment fails at settlement, and the limits cap the loss.
- **QR works like cash:** a QR not addressed to anyone goes to whoever scans and syncs it first.
- **Key backup:** the server backup is protected only by a 6-digit PIN.
- **Unofficial messaging channels:** WhatsApp (Baileys) is unofficial and SMS uses a personal SIM; at scale both need official channels (WhatsApp Business API, DLT-registered SMS).

### Roadmap

1. Deploy on a VPS with HTTPS, so the offline app installs on phones.
2. Server-approved offline spending allowance, to prevent double-spending.
3. Real recovery phrase, change PIN, and sign-out of other devices.
4. Receipt QR for merchants, and the amount built into the merchant QR.
5. Hindi and regional languages, plus spoken payment alerts.
6. Native app with keys in the phone's secure chip, and Bluetooth/NFC payments.
7. Bank or licensed PPI partner, real KYC, and a payment gateway for real money.

## Impact and poster lines

### Impact

- Digital payments where there is no network: villages, hills, crowded events and disaster zones.
- Small merchants get digital records instead of cash only, which can later help them get credit.
- Builds trust through instant on-phone verification and automatic settlement.
- Small, fixed limits and an offline-first design suit first-time digital payment users.

### Poster-ready lines

- **"Payments that don't need a signal."**
- No internet? Pay by QR. No data? Sync by SMS.
- Signed on your phone. Verified offline. Settled automatically.
- Key facts: Rs 500 per payment and Rs 2,000 per day offline; QR valid 60 seconds; three ways to settle (app, SMS, automatic refresh); Ed25519-signed payments end to end; installable app that opens with no network.
- Flow for a graphic: Sign up (online), then Pay by QR (offline), then Verify on phone, then Sync (data or SMS), then Settled + WhatsApp alert.

## Business Model Canvas

A draft canvas for a real-money version run with a partner bank or licensed issuer.

| Block | Content |
| --- | --- |
| Customer segments | Rural and semi-urban users with poor connectivity; small merchants (kirana stores, vendors, stalls); gig and migrant workers; event and market operators; NGOs and microfinance groups; disaster-relief agencies |
| Value propositions | Pay and receive with no internet; instant on-phone verification; automatic settlement over data or SMS; low limits for safety; a familiar UPI-like experience; digital records for merchants |
| Channels | Installable web app (no app store needed); merchant onboarding through local agents and shopkeepers; NGO and bank partnerships; WhatsApp for codes and alerts |
| Customer relationships | Self-service app; WhatsApp alerts and SMS confirmations; assisted onboarding via local agents; merchant support |
| Revenue streams | Small fee on instant withdrawals; merchant premium plan (analytics, multiple counters, settlement reports); payout services for organisations and government (benefit and relief disbursement); white-label licensing to banks and PPI issuers; transaction fees where regulation allows |
| Key activities | Building and securing the offline payment protocol; settlement and reconciliation; user and merchant onboarding; compliance (KYC, anti-money-laundering); fraud monitoring |
| Key resources | Offline signing and settlement technology; secure backend; SMS gateway and WhatsApp channels; partner bank or licence; brand and agent network |
| Key partners | Sponsor bank or licensed PPI issuer (or UPI via a bank); payment gateway and payouts provider; KYC provider; DLT-registered SMS provider; WhatsApp Business API provider; NGOs, microfinance groups and local agents |

| Block | Content |
| --- | --- |
| Cost structure | Cloud hosting and security audits; SMS and WhatsApp message costs; KYC checks per user; compliance and legal; customer support; agent commissions; a fraud loss reserve for offline payments |

## Regulatory note

Running SyncPay with real money in India needs an RBI PPI licence or a partner bank or licensed issuer. It must also follow the RBI framework for small offline payments, do KYC and anti-money-laundering checks, store payment data in India, and use official messaging channels.